→ Case Study - 2

12-10-26

* Securing the University Examination System

- A university uses an OS - based examination management system to store student records, examination records, faculty records & question papers. The system has 3 main user groups: Students, Faculty, & Administrators. Students should be able to view only their marks & download permitted learning materials. Faculty members need to view student records & enter or modify marks. Administrators manage user accounts, permissions & system configuration.

→ The university has assigned permissions through roles, but an review identifies the following events:

- At 10:00, the account Student07 has 3 failed login attempts.
- At 10:03, Student07 successfully logs in.
- At 10:04, Student07 attempts to open ExamMarks.xlsx, which contains marks for an entire class.
- At 10:05, the system records an attempted modification of ExamMarks.xlsx by Student07
- At 10:15, Faculty02 modifies marks in ExamMarks.xlsx & saves the file successfully
- At 10:20, an Administrator discovers that a former faculty member's account is still active.
- The audit log is stored on the same server & users with broad permissions may able to modify or delete it.

- The university wants to protect confidentiality, integrity & availability; prevent unauthorized access; maintain accountability; and investigate suspicious activity. You are asked to recommend appropriate OS - Access Control, security administration & auditing measures.

Q1) Identify the main security problems in the case study.

A) 1. Repeated failed logins : Student07 has 3 failed login attempts, indicating a possible brute-force attack or password guessing.

2. Unauthorized access : Student07 attempts to open ExamMarks.xlsx, which contains marks for the entire class.

3. Unauthorized modification : Student07 attempts to modify the marks file despite not having required permission.

4. Unprotected audit logs : The audit logs are stored on same server & may be modified or deleted by users with broad permissions, eg:- Admin.

Q2) Explain the difference b/w Authentication & Authorization using Student07 as an example.

A) Authenication :-

Process of verifying the identity of a user through credentials. Student07 successfully logs in at 10:03, meaning the system has authenticated the account.

Authorization :-

Determines what an authenticated user is allowed to do. Student07 may access personal marks but shouldn't be able or allowed to views or modify the marks of the entire class.

Q3) Recommend an access - control policy for students, faculty & administrators. Justify your choice.

A) University should implement RBAC, Role-Based Access Control, where permissions are assigned according to user's roles.

1. Students :- Can view & download their own marks & permitted materials but can't access or modify other students' record.

2. Faculty :- Can view & modify marks only for the classes assigned to them.

3. Admins :- Can manage user accounts, permissions, & system config.

- Permissions should be reviewed regularly, unnecessary access should be removed, & former employees' accounts should be disabled immediately.

- Justification :- RBAC simplifies permission management, reduces unauthorized access & ensures that users receive only access required for their roles.

Q4) Prepare a suitable Access Control List (ACL) for ExamMarks.xlsx.

A) An Access Control List specifies which users or groups can perform particular operations on a file.

User group	Write	Read	Delete
Students	No	No	No
Faculty	Yes	Yes	No
Admins	No	Limited/ authorized	No

- Students should access their own marks through portal, rather than whole class.
- Faculty should be able to update marks for their assigned classes.
- Admins should manage accounts & permissions rather than modify / delete records.

Q5) Explain ~~how~~ how the principle of least privilege should be applied.

A) The PoLP states that every user should receive only the minimum permissions necessary to perform duties.

1. Students :- Access their own marks, no editing.

2. Faculty :- Access only assigned classes, no unnecessary detetion rights

3. Admins :- Manage accounts & settings without unrestricted file access.

4. Former faculty :- Disable their accounts & revoke all their permissions.

- Reduces risk of accidental changes, data theft & unauthorised access.

Q6) Interpret the audit events from 10:00 to 10:05. What should the security team do next?

A) The sequence is suspicious because Student07 has 3 failed login attempts at 10:00, successfully logs in at 10:03, attempts to open complete marks list at 10:04 & attempts to modify at 10:05

These events may indicate a password-guessing attempt followed by an attempt to modify unauthorized data. Suspicious but do not prove an attack.

Security team should :

1. Verify whether Student07's login was legitimate
2. Check IP addresses, permissions & login records.
3. Investigate whether the file was accessed or modified.
4. Restrict the user temporarily if a serious risk is identified.
5. Preserve audit logs & investigate it further.

Q7) List 5 events recorded in audit logs.

A) 1. Successful & failed login attempts
2. File access, including attempts to open restricted files.
3. Account creation, deletion, activation & deactivation.
4. Permission & role changes
5. Attempts to alter audit logs.

Q8) Explain why audit logs must be protected & recommend two ways to protect them.

A) Audit logs provide evidence of user activities & help detect suspicious activity / behavior, investigate incidents & establish accountibility. If they are modified or deleted, important evidence may be lost or manipulated.

- Ways to protect Audit logs

1) Restricted access :- Restrict log access to authorized security personnel.

2) Use tamper-resistant storage :- Store logs on a separate, secure server with backups & tamper protection.

Q9) What action should be taken regarding the former faculty's active account?

A) 1. University should immediately disable the former faculty members account because the person no longer requires access to university systems.

2. Revoke the too account's login previleges, active sessions & associated access tokens.

3. Remove the g account from groups & revoke it's permissions to files, applications & other resources.

4. Review accounts recent activity & audit logs for any suspicious activity from the certain former faculty's account.

Q10) Suggest a practical incident-response & corrective-action plan for the university.

A) 1. Investigation :- Examine audit logs, login records, & file activity to determine whether unauthorized access or modification occurred.

2. Containment :- Restrict suspicious accounts if necessary, terminate suspicious sessions & immediatly disable the former faculty member's account.

3. Corrective Action :- Review user permissions, implement RBAC, enforce least privilege & store audit logs securely on a separate server.

4. Follow-up Monitoring :- Monitor login attempts, file modifications & permission charges. Conduct regular security audits to ensure the corrective measures are effective.